Práctica 1: Reconocimiento Pasivo

Objetivo: Endesa.com

0.1. Resumen

En este informe se ha realizado una auditoría de seguridad "pasiva" sobre la empresa Endesa. Esto significa que hemos buscado información disponible públicamente en Internet (como un detective) sin tocar ni atacar sus servidores reales. Se han identificado sus dominios de internet, los sistemas de protección que usan (como Imperva) y se ha comprobado si existen documentos privados expuestos en Google. Los resultados indican que Endesa mantiene una buena higiene digital, aunque se han localizado numerosos portales de acceso que podrían ser puntos de interés para un atacante.

Índice

Contents

0.1. Resumen . . . 1
Índice . . . 1
0.2. Introducción . . . 2
0.3. Investigación de Registros DNS . . . 2
0.3.1. Descripción de Registros Técnicos . . . 2
0.3.2. Discusión: Reconocimiento Pasivo vs. Activo . . . 2
0.3.3. Auditoría OSINT sobre Endesa . . . 3
0.4. Resultados de la Auditoría . . . 5
0.5. Conclusiones . . . 6
0.6. Bibliografía . . . 7
Bibliography . . . 7

0.2. Introducción

El reconocimiento es la primera fase de cualquier auditoría de ciberseguridad. En este laboratorio, aplicamos técnicas OSINT (Open Source Intelligence) para perfilar la infraestructura digital de Endesa. El objetivo es demostrar cómo un atacante o un auditor puede obtener datos críticos (servidores, subdominios y proveedores tecnológicos) utilizando únicamente herramientas gratuitas y bases de datos públicas, cumpliendo estrictamente con el marco ético de no interactuar con los sistemas de la víctima.

0.3. Investigación de Registros DNS

El Sistema de Nombres de Dominio (DNS) es fundamental para la resolución de nombres en Internet. Desde la perspectiva de OSINT, el análisis de estos registros permite identificar la infraestructura crítica de la organización sin interactuar directamente con ella [1].

0.3.1. Descripción de Registros Técnicos

A continuación, se detallan los registros analizados y su relevancia en el reconocimiento:

Registro	Descripción y Utilidad en Auditoría
A	Mapea un nombre de dominio a una dirección IPv4. Permite identificar el hosting principal.
AAAA	Versión IPv6 del registro A. Revela infraestructura de red moderna.
MX (Mail Exchange)	Indica los servidores de correo. Permite deducir si usan servicios como Office 365 o Google Workspace.
TXT	Contiene texto arbitrario. Se usa para registros SPF/DKIM que revelan otros servicios autorizados.
CNAME	Alias de un dominio. Útil para descubrir el uso de CDNs como Cloudflare o Akamai.
NS	Servidores de nombres autoritativos. Identifica quién gestiona el DNS de la empresa.
SOA	Información administrativa de la zona. Indica la frecuencia de actualización de los datos.
PTR	Resolución inversa (IP a nombre). Confirma la identidad del propietario de una IP.

Table 1: Resumen de registros DNS y su impacto en el reconocimiento.

0.3.2. Discusión: Reconocimiento Pasivo vs. Activo

El reconocimiento se clasifica según la interacción con el objetivo:

- **Reconocimiento Pasivo:** Se ha realizado consultando bases de datos de terceros y servidores DNS públicos (como 8.8.8.8). Al no realizar consultas directamente a los servidores autoritativos de la empresa, no existe registro de nuestra actividad en sus logs.

- **Reconocimiento Activo:** Acciones como la Transferencia de Zona (AXFR) o el **fuzzing** de subdominios contra los servidores de la empresa se consideran activas. Estas técnicas han sido descartadas en este trabajo para cumplir con el código ético y las restricciones de la práctica.

Mientras que herramientas como dig o nslookup podrían cruzar la línea hacia el reconocimiento activo si se dirigen contra los NS de la empresa, el uso de plataformas como [2] garantiza la pasividad al actuar como un intermediario que ya posee los datos indexados.

Para la obtención de estos datos se han utilizado exclusivamente fuentes de agregación de terceros como DNSDumpster [2], visto en [3] y el análisis de registros públicos de transparencia de certificados mediante crt.sh [4]. Estas herramientas garantizan una metodología 100% pasiva, ya que la información se extrae de bases de datos indexadas previamente, sin establecer comunicación con la infraestructura de Endesa.

0.3.3. Auditoría OSINT sobre Endesa

Empecé por mirar en la web de DNSDumpster donde conseguí sacar el mapa de la empresa Endesa pero el MX records donde están los correos de los empleados pero me salía vacío. Probé a usar otras páginas web como viewDNS.info o Pentest-tools y me seguía sin salir nada asi que solo tengo el mapa de la empresa.

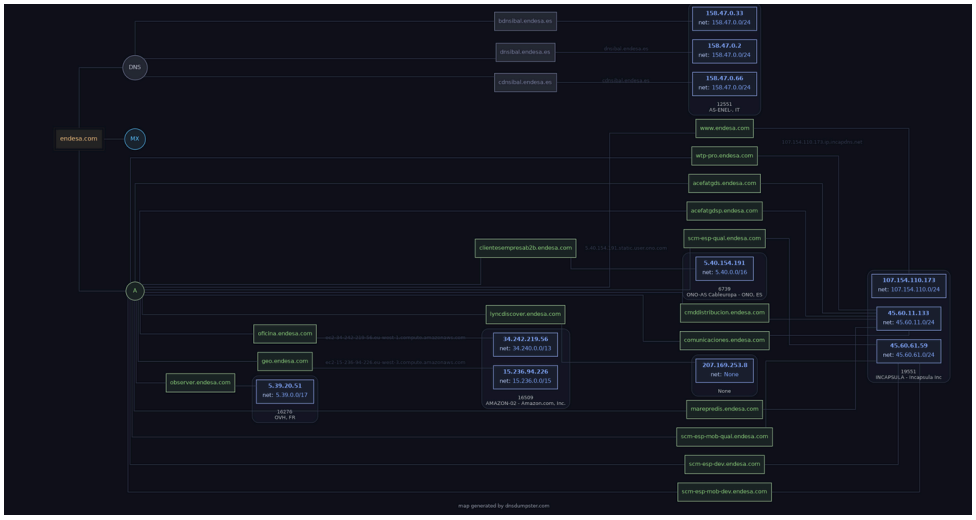

Figure 1: Mapa empresa Endesa [2].

Posteriormente busqué una página web donde consiga ver los subdominios y certificados de Endesa eso lo conseguí hacer con [4] Donde puse %.endesa.com y me salió una extensa tabla donde se consiguen ver activos reales como comunicaciones.endesa.com o oficina.endesa.com y varios de desarrollo como dev o qual.

También se ve en la tabla que aparece mucho imperva.com con esto conseguimos saber que Endesa usa imperva como WAF que es similar a Akamai y en cuanto a las certificadoras usan GlobalSign y Lets Encrypt.

24907177228	2026-03-10	2026-03-10	2026-03-11	imperva.com	endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24907177778	2026-03-10	2026-03-10	2026-03-11	imperva.com	*.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24904056238	2026-03-10	2026-03-10	2026-03-11	imperva.com	scm-esp-mob-qual.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24904749310	2026-03-10	2026-03-10	2026-03-11	imperva.com	scm-esp-mob-dev.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24903567498	2026-03-10	2026-03-10	2026-03-11	imperva.com	scm-esp-qual.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24904455173	2026-03-10	2026-03-10	2026-03-11	imperva.com	scm-esp-dev.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24903543732	2026-03-10	2026-03-10	2026-03-11	imperva.com	endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24903567334	2026-03-10	2026-03-10	2026-03-11	imperva.com	*.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24835944309	2026-03-07	2026-03-07	2026-03-08	imperva.com	acefatgdsp.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24835944470	2026-03-07	2026-03-07	2026-03-08	imperva.com	comunicaciones.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24851452269	2026-03-07	2026-03-07	2026-03-08	imperva.com	marepredis.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24835931188	2026-03-07	2026-03-07	2026-03-08	imperva.com	acefatgds.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24842369503	2026-03-07	2026-03-07	2026-03-08	imperva.com	cmddistribucion.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24835944949	2026-03-07	2026-03-07	2026-03-08	imperva.com	*.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24835930421	2026-03-07	2026-03-07	2026-03-08	imperva.com	endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24787284130	2026-03-04	2026-03-04	2026-06-02	oficina.endesa.com	oficina.endesa.com	C=US, O=Let's Encrypt, CN=E8
24787259913	2026-03-04	2026-03-04	2026-06-02	oficina.endesa.com	oficina.endesa.com	C=US, O=Let's Encrypt, CN=E8
24767610823	2026-03-03	2026-03-03	2026-03-04	imperva.com	endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24767610880	2026-03-03	2026-03-03	2026-03-04	imperva.com	*.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24764317868	2026-03-03	2026-03-03	2026-03-04	imperva.com	scm-esp-dev.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24764297642	2026-03-03	2026-03-03	2026-03-04	imperva.com	scm-esp-qual.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24764299733	2026-03-03	2026-03-03	2026-03-04	imperva.com	scm-esp-mob-dev.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24764297780	2026-03-03	2026-03-03	2026-03-04	imperva.com	scm-esp-mob-qual.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24764312725	2026-03-03	2026-03-03	2026-03-04	imperva.com	*.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24764296910	2026-03-03	2026-03-03	2026-03-04	imperva.com	endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24759456061	2026-03-03	2026-03-03	2026-03-04	imperva.com	*.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24759456195	2026-03-03	2026-03-03	2026-03-04	imperva.com	endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24696126460	2026-02-28	2026-02-28	2026-03-01	imperva.com	marepredis.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24696126459	2026-02-28	2026-02-28	2026-03-01	imperva.com	cmddistribucion.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24696159905	2026-02-28	2026-02-28	2026-03-01	imperva.com	comunicaciones.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24696125954	2026-02-28	2026-02-28	2026-03-01	imperva.com	acefatgdsp.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24696126597	2026-02-28	2026-02-28	2026-03-01	imperva.com	acefatgds.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24696126526	2026-02-28	2026-02-28	2026-03-01	imperva.com	endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24696125922	2026-02-28	2026-02-28	2026-03-01	imperva.com	*.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1
24682162056	2026-02-27	2026-02-27	2026-02-28	imperva.com	scm-esp-mob-dev.endesa.com	C=BE, O=GlobalSign nv-sa, CN=GlobalSign Atlas R3 DV TLS CA 2026 Q1

Figure 2: Enumeración de subdominios y certificados de Endesa [4].

Para hacer los dorks probé tres de los cuales ninguno me dió resultados. El primero fue para los logins site:endesa.com inurl:login | inurl:portal. EL segundo es para encontrar documentos técnicos o normativos site:endesa.com filetype:pdf “prohibida su reproducción”. Por último prové un dork para monitorizar futuras fugas de archivos de configuración. El hecho de que no salga nada hoy significa que su seguridad es buena, pero el dork es una herramienta preventiva.

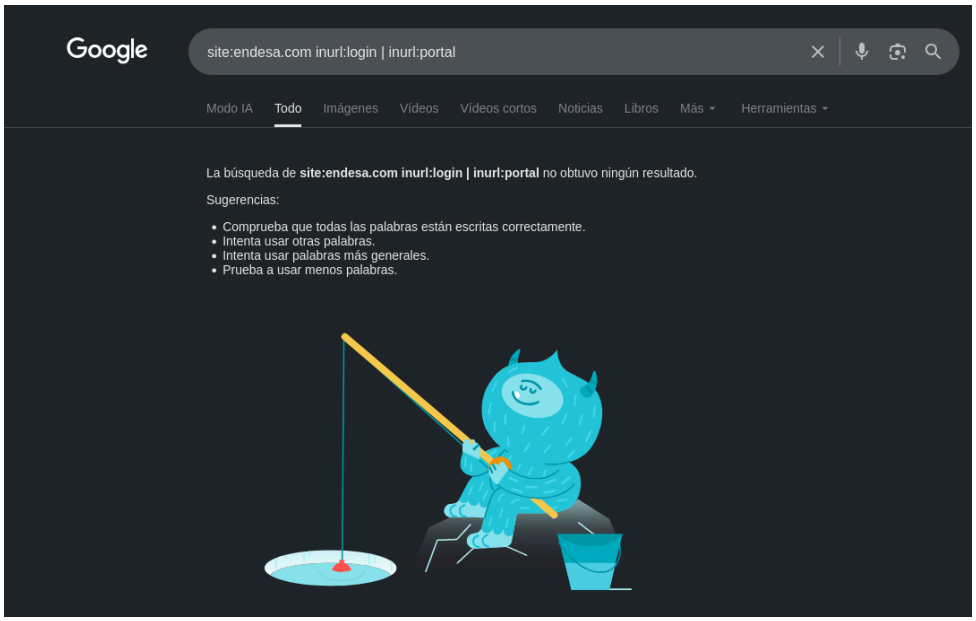

Figure 3: Para logins.

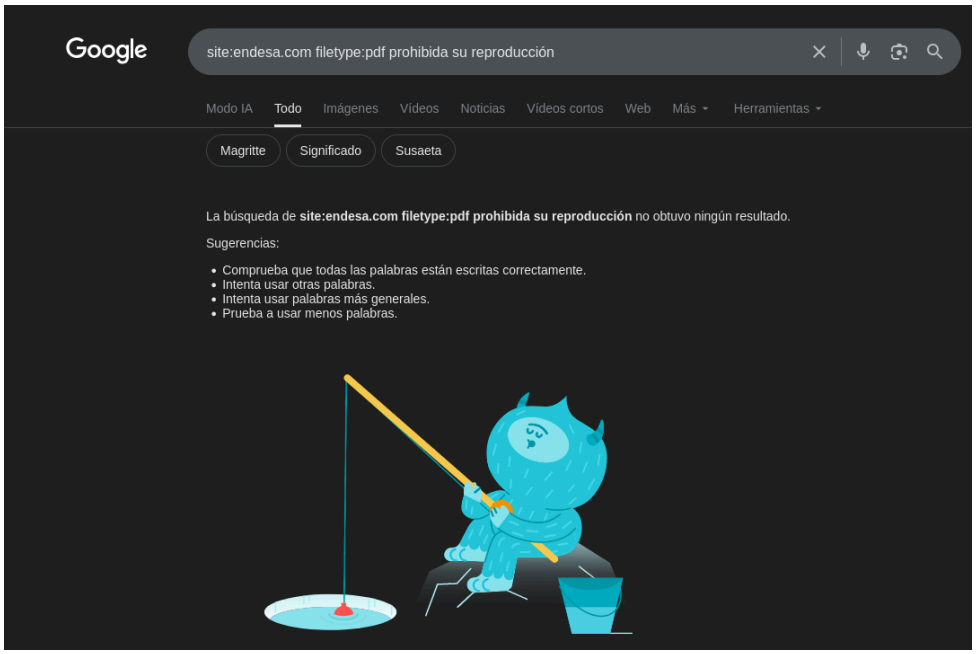

Figure 4: Para documentos técnicos.

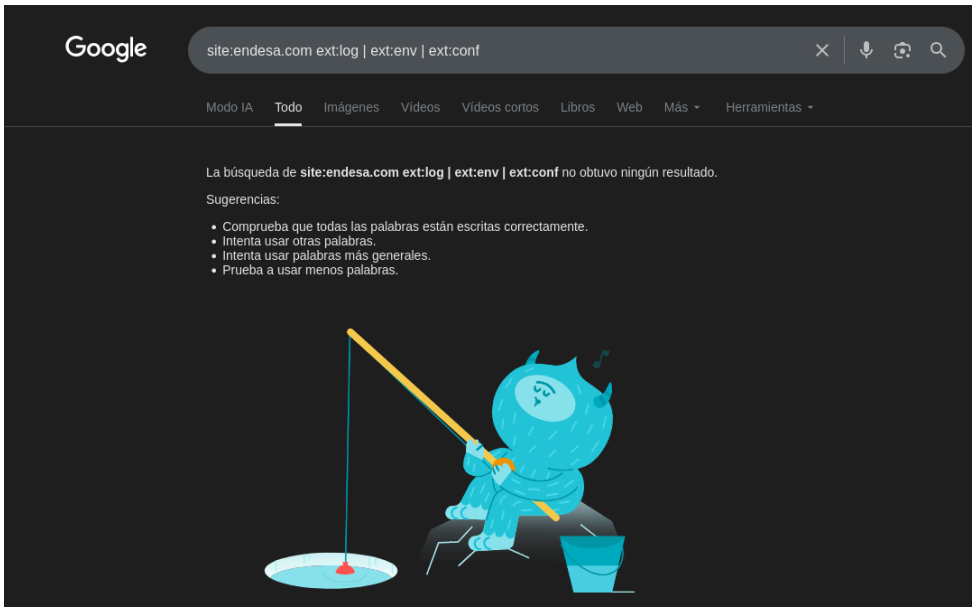

Figure 5: Monitorizar futuras fugas.

0.4. Resultados de la Auditoría

A continuación, se sintetizan los activos y tecnologías identificados durante el proceso de reconocimiento:

Categoría	Hallazgo OSINT
Proveedor de Seguridad	Imperva Inc. (Identificado mediante certificados SSL)
Gestión de Certificados	GlobalSign y Let's Encrypt
Infraestructura Web	Uso de subdominios para entornos de desarrollo (dev, qual)
Proveedores DNS	Akamai Technologies
Estado de Dorking	Bajo nivel de exposición de documentos sensibles (Seguridad Preventiva)

Table 2: Resumen ejecutivo de hallazgos tecnológicos.

0.5. Conclusiones

La investigación realizada permite concluir que Endesa posee una infraestructura robusta y madura. El uso de un WAF como Imperva sugiere una inversión significativa en protección perimetral. Aunque no se han localizado fugas de documentos críticos mediante Google Dorks, la exposición de subdominios de desarrollo representa un riesgo potencial si estos entornos no están tan protegidos como el portal principal. Como aprendizaje técnico, este laboratorio destaca la importancia de la transparencia de certificados (crt.sh) como una de las fuentes más ricas para el mapeo de activos.

0.6. Bibliografía

Bibliography

[1] A. Robledano Abasolo, "Técnicas de Hacking: Práctica 1 - Recogida de información pasiva." Universidad Europea de Madrid, 2026.

[2] HackerTarget, "DNSDumpster Tool - DNS recon and research." [Online]. Available: https://dnsdumpster.com/

[3] S. Talwar and A. Mavi, "An overview of DNS domains/subdomains vulnerabilities scoring framework," *International journal of applied engineering and technology*, vol. 5, pp. 274–280, 2023.

[4] Sectigo, "crt.sh Certificate Search." [Online]. Available: https://crt.sh/